

ACTIVIDAD 01

ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Caso: Aurora Market

Programa: Hacker Women Council · Ethical Hacking

Nombre: Mariana Ponce Sepulveda

1 OBJETIVO DEL PENTEST

El objetivo concreto de realizar un pentest a **Aurora Market** es evaluar de manera controlada la seguridad de su aplicación web para determinar si existen vulnerabilidades que puedan ser aprovechadas por un atacante para acceder a información, cuentas o funcionalidades que no debería tener disponibles.

La evaluación busca conocer **qué tan resistente es la aplicación frente a un posible ataque externo**, especialmente en aquellos puntos relacionados con la autenticación, autorización, gestión de sesiones y control de acceso entre diferentes usuarios. Esto es especialmente importante en Aurora Market debido a que la aplicación administra información relacionada con clientes, productos y pedidos.

No se busca solamente encontrar vulnerabilidades, sino **comprender el riesgo que representan para el negocio**. Por ejemplo, si un usuario pudiera acceder a información perteneciente a otra cuenta, sería necesario determinar qué información podría quedar expuesta, qué impacto tendría para los clientes y qué medidas deberían implementarse para evitar que esta situación ocurra.

El pentest permitirá a Aurora Market obtener una visión de su nivel de seguridad desde la perspectiva de un atacante externo, identificar debilidades antes de que puedan ser aprovechadas y establecer medidas de mitigación. De esta manera, la evaluación aporta valor porque permite **reducir riesgos, proteger la información de los clientes y fortalecer la seguridad de la aplicación sin afectar su disponibilidad**.

2 ALCANCE

Dentro del alcance

- Aplicación web de Aurora Market.
- Mecanismos de autenticación.
- Gestión de sesiones.
- Control de acceso entre cuentas y tipos de usuarios.
- Gestión y consulta de información de clientes.
- Funcionalidades relacionadas con productos y pedidos.
- Validación de entradas.
- Información y funcionalidades accesibles desde la aplicación.

Fuera del alcance

- Redes sociales de Aurora Market.
- Proveedores y servicios de terceros.
- Cuentas de correo electrónico.
- Equipos de empleados.
- Infraestructura no autorizada.
- Pruebas de ingeniería social.
- Actividades que puedan interrumpir el servicio.
- Modificación, eliminación o extracción innecesaria de información real.

3 AUTORIZACIÓN Y CONDICIONES

Antes de comenzar, se debe contar con:

1. Autorización formal y escrita de Aurora Market.
2. Alcance aprobado.
3. Cuentas de prueba para los diferentes tipos de usuarios.
4. Autorización para evaluar las funcionalidades incluidas.
5. Un contacto responsable dentro de Aurora Market.

Todas las actividades deberán ejecutarse exclusivamente sobre los sistemas autorizados.

Además, se evitarán acciones que puedan afectar la disponibilidad del servicio o modificar información real de clientes. Cualquier vulnerabilidad encontrada deberá ser documentada y comunicada de manera responsable.

4 TIPO DE PENTEST

Black-box

Se utilizará una metodología **Black-box**, debido a que inicialmente el equipo de Ethical Hacking contará con información técnica limitada sobre la arquitectura interna de Aurora Market.

El objetivo será evaluar la aplicación desde una perspectiva similar a la de un atacante externo autorizado, utilizando únicamente la información que pueda obtenerse mediante técnicas de reconocimiento y los accesos de prueba proporcionados por Aurora Market.

Esto permitirá determinar qué información puede descubrir un atacante y qué puntos de entrada podrían representar un riesgo para la organización.

PLANIFICACIÓN DEL PENTEST

Elemento	Plan
Objetivos	Identificar y validar vulnerabilidades, especialmente en autenticación, autorización y control de acceso.
Alcance	Aplicación web autorizada y sus funcionalidades de usuarios, sesiones, productos y pedidos.
Permisos	Autorización formal, alcance definido, cuentas de prueba y contacto responsable.
Metodología	OWASP Web Security Testing Guide (WSTG).
Información previa	Funcionalidades, tipos de usuarios, autenticación, sesiones y puntos de entrada autorizados.
Recursos	Equipo de pruebas, navegador, herramientas de análisis web, cuentas de prueba y registro de evidencias.
Programación	Pruebas coordinadas con Aurora Market y preferentemente durante horarios de menor actividad.

5. RECOPIACIÓN DE INFORMACIÓN

En esta etapa se recopilará información sobre Aurora Market antes de realizar pruebas de vulnerabilidades.

Se utilizarán fuentes abiertas (OSINT) y, cuando Aurora Market las proporcione, fuentes internas autorizadas.

Fuentes OSINT

Se podría recopilar información disponible públicamente sobre:

- Dominio y subdominios.
- Tecnologías utilizadas.
- Servidores y servicios expuestos.
- Direcciones IP asociadas.
- Información pública sobre la aplicación.
- Documentación técnica disponible públicamente.
- Información sobre frameworks o servidores.
- Posibles endpoints publicados.

Para esta etapa podrían utilizarse herramientas y técnicas como:

- WHOIS, para obtener información de registro del dominio cuando esté disponible.
- DNS/NSLookup o dig, para consultar registros DNS.
- WhatWeb, para identificar tecnologías utilizadas por la aplicación.
- Motores de búsqueda y técnicas OSINT para localizar información pública.

Fuentes internas autorizadas

Aurora Market podría proporcionar información como:

- URL oficial de pruebas.
- Cuentas de prueba.
- Tipos de usuario.
- Funcionalidades que deben evaluarse.
- Horarios autorizados.
- Información necesaria para diferenciar ambientes de prueba y producción.

La información interna no se utilizará para ampliar el alcance, sino para realizar una evaluación controlada sobre los recursos específicamente autorizados.

6. USO DE NMAP

Una herramienta importante durante el reconocimiento sería **Nmap**.

Nmap permitiría identificar, dentro del alcance autorizado:

- Puertos abiertos.
- Servicios disponibles.
- Versiones de determinados servicios.
- Posibles puntos de entrada de la infraestructura expuesta.

Por ejemplo, si durante el reconocimiento se identifica que un servidor expone determinados servicios, esta información permitiría conocer mejor la superficie de ataque y decidir qué elementos deben analizarse posteriormente.

El propósito de Nmap **no sería atacar el servidor**, sino obtener información técnica que ayude a comprender qué servicios están expuestos y cuáles podrían requerir una evaluación posterior.

7. USO DE OWASP ZAP

Para el análisis de la aplicación web se utilizaría **OWASP ZAP**.

ZAP permitiría observar y analizar la comunicación entre el navegador y la aplicación, ayudando a identificar:

- Solicitudes HTTP/HTTPS.
- Parámetros enviados.
- Endpoints.
- Cookies.
- Gestión de sesiones.
- Respuestas del servidor.
- Posibles problemas de configuración.
- Posibles vulnerabilidades de aplicaciones web.

También podría utilizarse para realizar análisis automatizados y posteriormente complementar estos resultados con pruebas manuales.

En Aurora Market sería especialmente útil para observar cómo funcionan las sesiones, autenticación y solicitudes relacionadas con las diferentes funcionalidades de usuarios.

8. HORARIOS DEL PENTEST

Considerando que Aurora Market establece que las pruebas deben realizarse durante horarios previamente acordados y procurando no afectar la disponibilidad del servicio, propondría realizar las actividades más sensibles durante períodos de menor actividad.

Horario propuesto

Lunes a viernes: 22:00 a 02:00 horas.

Este horario permitiría realizar las pruebas cuando previsiblemente existe menor actividad de usuarios.

Una segunda ventana de trabajo podría ser:

Sábado: 18:00 a 22:00 horas, previa coordinación con Aurora Market.

Las actividades de reconocimiento pasivo y análisis de información pública podrían realizarse fuera de estas ventanas, debido a que no requieren generar una carga significativa sobre la aplicación.

Las pruebas que puedan generar mayor cantidad de solicitudes deberán concentrarse dentro de la ventana autorizada y realizarse de forma controlada.

9. FASE DE RECONOCIMIENTO

Durante el reconocimiento se buscará comprender cómo está construida y expuesta la aplicación antes de intentar identificar vulnerabilidades.

Primero se identificarán los dominios y recursos autorizados y posteriormente se analizaría la superficie de ataque.

Se buscaría conocer:

- Dominios y subdominios.
- Direcciones IP asociadas.
- Puertos abiertos.
- Servicios disponibles.
- Tecnologías utilizadas.
- Servidores web.
- Endpoints.
- Formularios.
- Mecanismos de autenticación.
- Tipos de usuario.
- Gestión de sesiones.
- Funcionalidades relacionadas con pedidos y productos.
- Posibles puntos donde se reciben datos proporcionados por usuarios.

Para el análisis de puertos y servicios se utilizaría **Nmap**, mientras que para conocer las tecnologías de la aplicación se podrían utilizar herramientas como **WhatWeb**.

Posteriormente, **OWASP ZAP** permitiría observar la aplicación y descubrir endpoints y parámetros utilizados durante la navegación autorizada.

El objetivo de esta fase sería construir un mapa de la superficie de ataque para saber **qué elementos deben evaluarse posteriormente**, sin realizar todavía explotación.

10. ANÁLISIS DE VULNERABILIDADES

En esta fase se analizarían los elementos identificados durante el reconocimiento.

Se utilizarían principalmente:

OWASP ZAP

Para analizar la aplicación web y buscar posibles problemas relacionados con:

- Autenticación.
- Sesiones.
- Control de acceso.
- Parámetros.
- Entradas de usuario.
- Cabeceras.
- Configuraciones inseguras.
- Información expuesta.

Nmap

Los resultados obtenidos durante el reconocimiento permitirían identificar servicios expuestos que posteriormente deban ser revisados.

OWASP WSTG

La evaluación se organizaría utilizando **OWASP Web Security Testing Guide**, ya que esta metodología contempla

categorías relevantes para el escenario de Aurora Market, como autenticación, autorización, gestión de sesiones, validación de entradas y lógica de negocio.

El propósito de esta etapa sería **determinar qué posibles vulnerabilidades existen y cuáles requieren una validación posterior**, sin ejecutar todavía una explotación.

11. EXPLOTACIÓN

Una vez identificadas posibles vulnerabilidades, se seleccionarán aquellas que puedan validarse de forma segura.

La explotación se realizará únicamente sobre el entorno y las cuentas autorizadas por Aurora Market.

Por ejemplo, si durante el análisis se detectara una posible falla de control de acceso entre usuarios, se podría comprobar de manera controlada si una cuenta de prueba puede acceder a un recurso perteneciente a otra cuenta de prueba.

El objetivo será confirmar la existencia de la vulnerabilidad y determinar su impacto, **sin modificar, eliminar ni extraer información real de clientes**.

12. POST-EXPLOTACIÓN

Después de confirmar una vulnerabilidad, se analizará hasta dónde podría llegar su impacto.

Se buscará determinar:

- Qué información podría quedar expuesta.
- Qué funcionalidades podrían verse comprometidas.
- Qué tipo de usuario podría aprovechar la vulnerabilidad.
- Qué consecuencias tendría para Aurora Market.
- Qué riesgo podría representar para los clientes.

La recopilación de evidencia será mínima y controlada. No se extraerá información innecesaria.

13. INFORME FINAL

Finalmente se elaborará un informe para Aurora Market.

Cada vulnerabilidad debería incluir:

- Nombre de la vulnerabilidad.
- Descripción.
- Componente afectado.
- Evidencia obtenida.
- Condiciones necesarias para reproducirla.
- Impacto.
- Nivel de riesgo.
- Recomendación de mitigación.

El informe debe permitir que Aurora Market comprenda **qué ocurrió, por qué representa un riesgo y qué debería hacer para corregirlo**.

También se incluirá un resumen ejecutivo para que los responsables no técnicos puedan comprender los principales riesgos encontrados.

14 METODOLOGÍA

Metodología seleccionada: OWASP Web Security Testing Guide (WSTG)

El OWASP Web Security Testing Guide (WSTG) es una guía de referencia para realizar pruebas de seguridad en aplicaciones web y servicios web. Proporciona un marco de buenas prácticas para estructurar evaluaciones de seguridad de forma sistemática. Entre sus categorías se encuentran recopilación de información, gestión de identidades, autenticación, autorización, gestión de sesiones, validación de entradas, manejo de errores y lógica de negocio.

¿Por qué es útil para Aurora Market?

Esta metodología es adecuada porque el alcance del pentest se concentra en una aplicación web. Además, el posible acceso de un usuario a información perteneciente a otra cuenta hace especialmente importante evaluar los mecanismos de autenticación, autorización y control de acceso. Estas áreas forman parte de las pruebas contempladas por el WSTG.

Aplicación al caso

- **Autenticación:** verificar cómo la aplicación comprueba la identidad de los usuarios.
- **Autorización:** comprobar que cada usuario solamente pueda acceder a los recursos que le corresponden.
- **Gestión de sesiones:** revisar los controles relacionados con las sesiones de usuario.
- **Validación de entradas:** analizar cómo la aplicación procesa los datos proporcionados por los usuarios.
- **Lógica de negocio:** identificar comportamientos que puedan permitir utilizar las funcionalidades de una forma no prevista.

15. CONCLUSIÓN

El pentest propuesto para Aurora Market permitirá evaluar la seguridad de su aplicación web desde la perspectiva de un atacante externo autorizado, manteniendo siempre las restricciones establecidas por la organización.

La evaluación comenzará con la recopilación de información y el reconocimiento de la superficie de ataque, utilizando herramientas como Nmap y técnicas OSINT. Posteriormente se realizará el análisis de la aplicación mediante herramientas como OWASP ZAP y siguiendo como referencia el OWASP Web Security Testing Guide.

Las posibles vulnerabilidades serán posteriormente validadas de forma controlada, evitando afectar la disponibilidad de la aplicación o comprometer información real de los clientes.

De esta manera, el pentest no se limita a encontrar vulnerabilidades, sino que permite a Aurora Market **comprender sus riesgos, priorizar las debilidades de seguridad y aplicar medidas de protección antes de que un atacante real pueda aprovecharlas**.

Fuente

OWASP Foundation. **Web Security Testing Guide (WSTG)**.